Лабораторна робота №7
Робота з Cookies та механізмом сесій

Крайняк Михайло Юрійович, 451 група

1. Тема, мета і середовище

Мета: навчитися створювати, читати, змінювати й видаляти cookies у PHP, зберігати стан між запитами за допомогою сесії та перевіряти дані клієнта. Результат — «Панель студентського клубу» з налаштуванням оформлення, історією відвідувань і списком обраних заходів.

Фактична версія PHP вебсервера: 8.2.12 (заголовок відповіді `X-Powered-By: PHP/8.2.12`; PHP із XAMPP). OSPanel і окремий PHP 8.1 на комп'ютері не встановлені. Тому застосунок запускався вбудованим сервером того самого PHP. Код використовує лише можливості PHP 8.1 і старших (тип `never`, `str_starts_with()`), тому працює й на 8.1.

Адреса запуску: `http://127.0.0.1:8070/lab-07/`. Кореневий каталог сервера містить папку `lab-07`, що вказує на `src`, — так само, як `C:\xampp\htdocs\lab-07`. Тому шлях cookies `/lab-07/` відповідає адресі. Скрізь використано один хост `127.0.0.1`. Перевірено, що на `localhost:8070` тема з `127.0.0.1` не діє, бо cookies прив'язані до хоста.

Інструменти перевірки:

- `curl` — скрипт `tools/checks.sh` проходить усю таблицю перевірок;
- Microsoft Edge 156 — запускався без вікна і керувався через протокол засобів розробника (DevTools Protocol, скрипт `tools/browser_check.mjs`). Звідти взято журнал Network із заголовками `Set-Cookie`/`Cookie`, вміст сховища cookies, результат `document.cookie` і знімки сторінок;
- W3C Nu HTML Checker.

Ідентифікатори сесії та CSRF-токени в журналах і на знімках замінено на «…». Для порівняння сесій наведено лише висновок «змінився/не змінився».

2. Перелік файлів

Файл	Призначення
`src/bootstrap.php`	Спільний файл. **Рядки 1–52** — готова заготовка з методички без змін (константи cookie, параметри сесії, `session_start()`, CSRF-токен, `e()`, `cookieOptions()`, `requireValidPost()`); програмна перевірка підтвердила збіг. **Нижче позначки «Власні доповнення»** — власний код: каталог тем, `currentTheme()`, `postString()`, одноразові повідомлення, `redirect()`, `favorites()`, спільний шаблон сторінки
`src/index.php`	Головна: назва клубу, меню, поточна тема, кількість обраних, кнопка «Завершити сеанс»
`src/preferences.php`	Вибір теми (POST `save`) і окрема форма «Скинути налаштування» (POST `reset`)
`src/visits.php`	Лічильник переглядів і час попереднього перегляду в cookies на 7 днів
`src/favorites.php`	Каталог заходів і сесійний список обраного: `add`, `remove`, `clear`
`src/events.php`	Фіксований каталог заходів: `cinema`, `quiz`, `eco`, `trip`
`src/end_session.php`	Окремий POST-обробник «Завершити сеанс»
`src/style.css`	Оформлення: класи `theme-light` і `theme-dark`
`given/src/*.php`	Початкові демонстрації з методички, без змін; використано лише для порівняння (розділ 7)
`tools/checks.sh`, `tools/checks-output.txt`	Автоматичні перевірки curl та їх вивід
`tools/browser_check.mjs`, `results/browser-output.txt`, `results/browser-log.json`	Сценарії в браузері Edge та журнал мережі й сховища cookies
`tools/render_evidence.py`	Будує сторінки «Network» і «Cookies» для знімків із журналу браузера
`results/w3c-validation.txt`	Результат перевірки згенерованого HTML валідатором W3C

Усі PHP-файли збережено в UTF-8 без BOM. Кожна сторінка починається з `require __DIR__ . '/bootstrap.php';`, а `setcookie()`, `session_start()` і `header()` викликаються до будь-якого виведення.

3. Рух даних cookies і відмінність від сесії

```
setcookie() у PHP → заголовок відповіді Set-Cookie → сховище браузера → заголовок Cookie
                                  наступного запиту → $_COOKIE
```

Розглянемо збереження теми (рис. 4).

1. Під час обробки POST `preferences.php` викликає `setcookie('club_theme', 'dark', cookieOptions(time() + THEME_TTL))`. Функція лише додає до відповіді заголовок `Set-Cookie: club_theme=dark; expires=…; Max-Age=2592000; path=/lab-07/; HttpOnly; SameSite=Lax` і повертає `true`.

2. У тому самому виконанні `$_COOKIE['club_theme']` не змінюється: масив заповнено із заголовка `Cookie` поточного запиту, коли нової cookie ще не було.
3. Сервер відповідає `303 See Other` із `Location: index.php`. Браузер зберігає cookie і робить новий GET-запит, уже із заголовком `Cookie: …; club_theme=dark`.
4. Лише в цьому новому запиті PHP заповнює `$_COOKIE['club_theme']`. Функція `currentTheme()` перевіряє значення за переліком і повертає `dark`.

Сесія працює інакше. Список обраного зберігається на сервері в `$_SESSION['favorites']`, тобто у файлі сесії PHP. Браузер отримує лише cookie `LAB07SESSID` з ідентифікатором сесії: сесійну (без `expires`), з атрибутами HttpOnly і SameSite=Lax. За цим ідентифікатором `session_start()` знаходить дані на сервері. Тому:

- список не видно у сховищі браузера (рис. 5), і клієнт не може його підробити;
- `$_SESSION` змінюється одразу в поточному запиті, а на диск записується наприкінці виконання;
- тема й історія відвідувань — це постійні cookies зі строком дії 30 і 7 днів. Вони переживають закриття браузера і завершення сеансу, а сесія — ні (рис. 15–16).

4. Хід роботи

Крок 1. Підготовка проєкту

Створено файли `bootstrap.php`, `index.php`, `preferences.php`, `visits.php`, `favorites.php`, а також власні `events.php`, `end_session.php` і `style.css`. Інші проєкти не видалялися.

Власні доповнення до `bootstrap.php` містять функції для перевірених даних і для перенаправлення. Тема для CSS-класу береться лише з переліку `THEMES`; масив, `unknown` або розмітка в cookie дають `light`.

```
const CLUB_NAME = 'Студентський клуб «Політ»';
const THEMES = ['light' => 'Світла', 'dark' => 'Темна'];
const THEME_COOKIE = 'club_theme';
const THEME_TTL = 30 * 24 * 60 * 60;   // 30 днів

date_default_timezone_set('Europe/Kyiv');

/** Тема з cookie: лише значення з переліку THEMES, інакше light (масив, unknown, розмітка). */
function currentTheme(): string
{
    $rawTheme = $_COOKIE[THEME_COOKIE] ?? null;
    return is_string($rawTheme) && array_key_exists($rawTheme, THEMES) ? $rawTheme : 'light';
}

/** Рядкове поле POST або null, якщо поля немає чи передано масив. */
function postString(string $name): ?string
{
    $value = $_POST[$name] ?? null;
    return is_string($value) ? $value : null;
}
```

```
/** 303 на GET-сторінку після успішного POST; до будь-якого виведення. */
function redirect(string $location): never
{
    header('Location: ' . $location, true, 303);
    exit;
}

/** Обрані заходи сесії (масив ідентифікаторів); некоректний стан замінюється порожнім масивом. */
function favorites(): array
{
    if (!isset($_SESSION['favorites']) || !is_array($_SESSION['favorites'])) {
        $_SESSION['favorites'] = [];
    }
    return $_SESSION['favorites'];
}
```

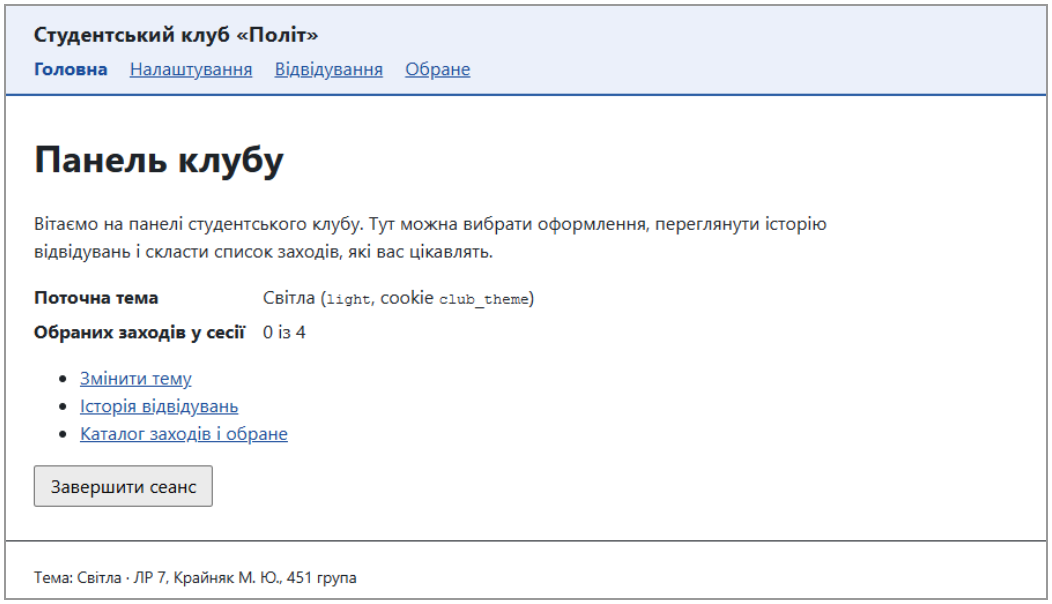


Рис. 1. Перший GET `index.php` без cookies: світла тема, обраних 0 із 4. У відповіді лише `Set-Cookie: LAB07SESSID=…; path=/lab-07/; HttpOnly; SameSite=Lax`.

Крок 2. Налаштування оформлення

Обробник POST у `preferences.php` перевіряє CSRF-токен (`requireValidPost()`), потім дію та тему. Невідома дія, тема або масив замість рядка дають 400 і повідомлення, а `setcookie()` при цьому не викликається. Результат `setcookie()` перевіряється: якщо він `false`, повідомлення про успіх немає.

```
if (($_SERVER['REQUEST_METHOD'] ?? 'GET') === 'POST') {
    requireValidPost();
    $action = postString('action');
    if ($action === 'save') {
        $newTheme = postString('theme');
        if ($newTheme === null || !array_key_exists($newTheme, THEMES)) {
            $error = 'Невідома тема. Виберіть «Світла» або «Темна».';
        } elseif (!setcookie(THEME_COOKIE, $newTheme, cookieOptions(time() + THEME_TTL))) {
            $error = 'Не вдалося підготувати cookie теми.';
        } else {
            setFlash('Тему «' . THEMES[$newTheme] . '» збережено на 30 днів.');
            redirect('index.php');
        }
    } elseif ($action === 'reset') {
```

```
        // Видалення: минулий строк дії й ті самі path/domain, що й під час створення.
        if (!setcookie(THEME_COOKIE, '', cookieOptions(time() - 3600))) {
            $error = 'Не вдалося підготувати видалення cookie теми.';
        } else {
            setFlash('Налаштування скинуто: використовується світла тема.');
            redirect('index.php');
        }
    } else {
        $error = 'Невідома дія.';
    }
    http_response_code(str_starts_with($error, 'Не вдалося') ? 500 : 400);
} elseif (($_SERVER['REQUEST_METHOD'] ?? 'GET') !== 'GET') {
```

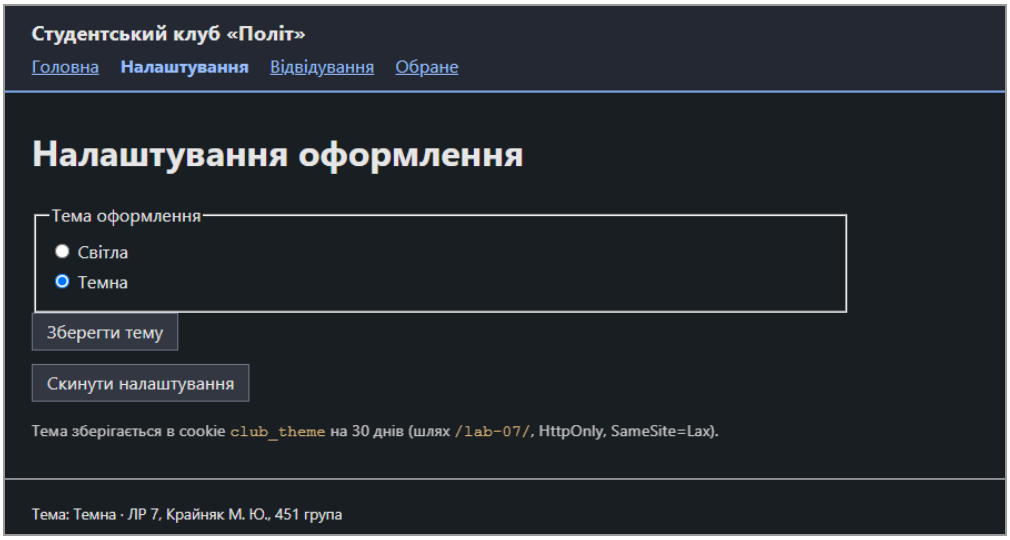


Рис. 2. `preferences.php` у темній темі. Форма вибору теми (радіокнопки з підписами в `fieldset`) і окрема POST-форма «Скинути налаштування». Обидві мають приховане поле `csrf`.

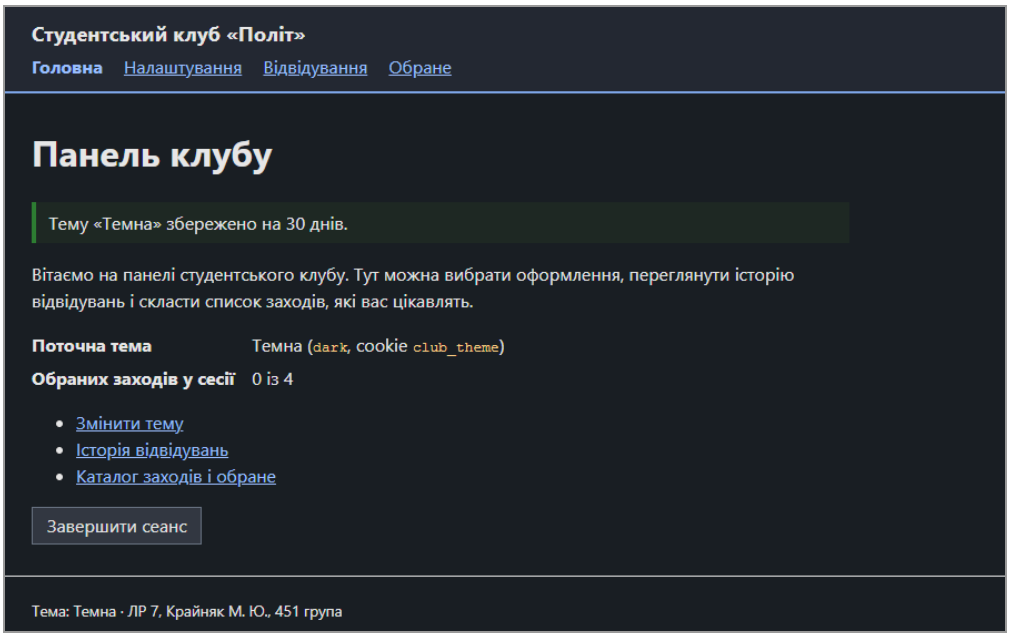


Рис. 3. Після «Зберегти тему»: POST → 303 → GET `index.php`. Тема застосована, показано одноразове повідомлення з сесії (розширення з кроку 5). Після оновлення сторінки повідомлення зникає.



Рис. 4. Журнал Network браузера Edge. POST-відповідь 303 містить `Set-Cookie: club_theme=dark` з `Max-Age=2592000` (30 днів). Наступний GET надсилає `Cookie: … club_theme=dark`. Нова тема читається лише в новому запиті.

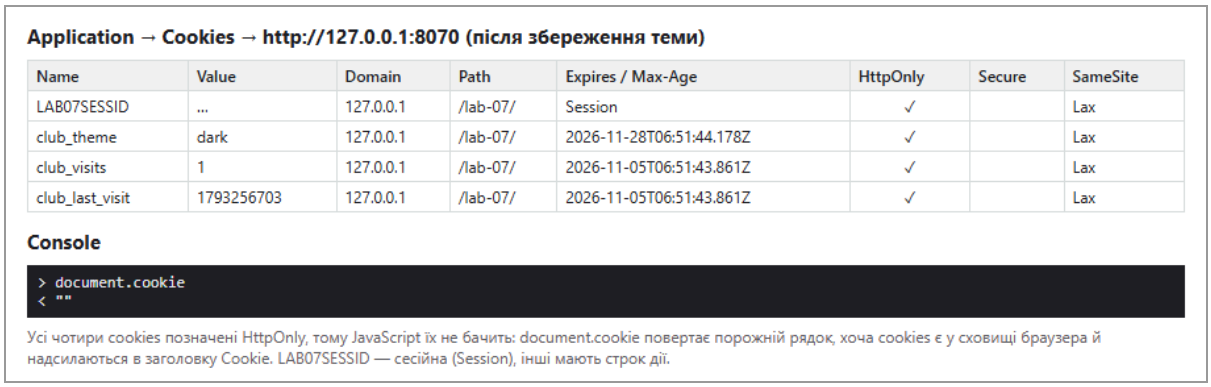


Рис. 5. Вміст сховища cookies браузера (таблиця на кшталт DevTools → Application → Cookies). Усі cookies мають атрибути HttpOnly, SameSite=Lax і path `/lab-07/`. Атрибут Secure не встановлено, бо це локальний HTTP. При цьому `document.cookie` повертає порожній рядок: JavaScript не бачить HttpOnly-cookie, хоча вона є у сховищі.

Крок 3. Лічильник відвідувань

Функція `cookieInt()` спочатку перевіряє рядковий тип і `ctype_digit()` (це відсікає масиви, «-1», «1.5», порожній рядок), потім `FILTER_VALIDATE_INT` з `min_range`/`max_range`. Порівняння `=== false` розрізняє допустиме значення 0 і невдалу перевірку. Рядки з початковими нулями (`007`) `FILTER_VALIDATE_INT` не приймає. Для часу верхня межа — поточний `time()`, тож майбутній час відкидається.

Порядок дій такий: спочатку запам’ятовуються перевірені старі значення, потім обчислюється новий номер (не більше 999999) і записується поточний час. Сторінка показує новий номер і *попередній* час. Некоректна cookie часу не скидає коректний лічильник. Рахуються лише GET-запити, інші методи отримують 405.

```
/** Ціле з cookie: лише рядок десяткових цифр у межах [min, max], інакше null (масив, -1, 1.5, завелике).
*/
function cookieInt(string $name, int $min, int $max): ?int
{
    $raw = $_COOKIE[$name] ?? null;
```

```
    if (!is_string($raw) || !ctype_digit($raw)) {
        return null;
    }
    $value = filter_var($raw, FILTER_VALIDATE_INT, ['options' => ['min_range' => $min, 'max_range' => $max]]);
    return $value === false ? null : $value;   // 0 — допустиме значення, false — невдала перевірка
}

// 1) Спочатку перевірені старі значення.
$now = time();
$previousCount = cookieInt(VISITS_COOKIE, 0, VISITS_MAX);
$previousTime = cookieInt(LAST_VISIT_COOKIE, 1, $now);

// 2) Новий номер перегляду (верхня межа 999999) і запис поточного часу.
$isNew = $previousCount === null;
$count = $isNew ? 1 : min($previousCount + 1, VISITS_MAX);
$expires = $now + VISITS_TTL;
$countSaved = setcookie(VISITS_COOKIE, (string) $count, cookieOptions($expires));
$timeSaved = setcookie(LAST_VISIT_COOKIE, (string) $now, cookieOptions($expires));
```

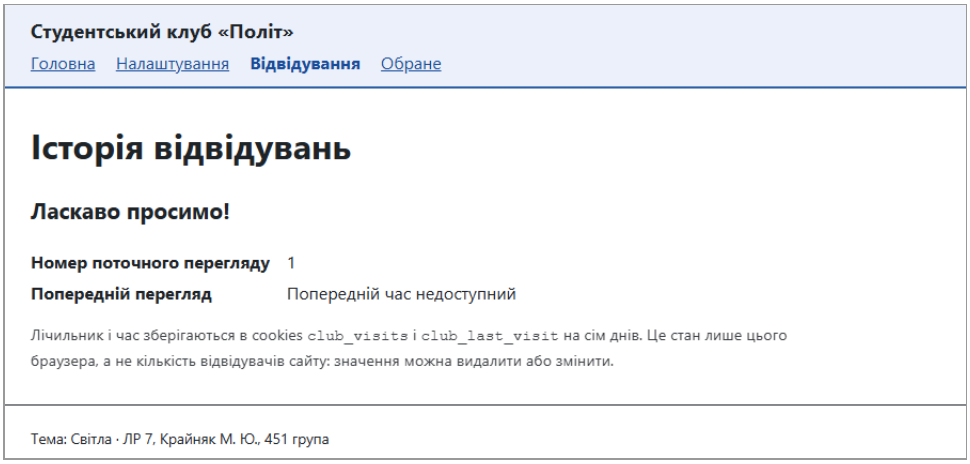


Рис. 6. Перший перегляд `visits.php`: «Ласкаво просимо!», номер 1, «Попередній час недоступний».

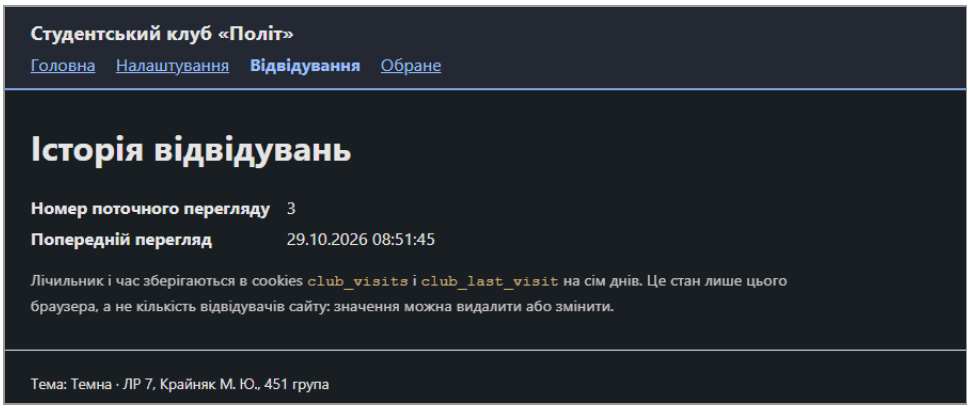


Рис. 7. Третій перегляд: номер 3 і час другого перегляду (`date('d.m.Y H:i:s')`, часовий пояс Europe/Kyiv).



Рис. 8. Другий і третій GET `visits.php`. Кожна відповідь записує `club_visits` і `club_last_visit` (Unix-час) з `Max-Age=604800` (7 днів); наступний запит їх надсилає.

Крок 4. Сесійний список обраного

Дії `add`, `remove`, `clear` надходять лише через POST із CSRF-токеном. Перевіряються дія, рядковий тип і наявність ідентифікатора в серверному каталозі `EVENTS`. Назви заходів беруться з каталогу й екрануються. Повторне додавання не створює дубліката, видалення відсутнього заходу не є помилкою. Після дії виконується перенаправлення 303 на GET.

```
if (($_SERVER['REQUEST_METHOD'] ?? 'GET') === 'POST') {
    requireValidPost();
    $action = postString('action');
    $id = postString('id');
    $list = favorites();
    if ($action === 'clear') {
        $_SESSION['favorites'] = [];
        setFlash('Список обраного очищено.');
        redirect('favorites.php');
    } elseif ($action !== 'add' && $action !== 'remove') {
        $error = 'Невідома дія.';
    } elseif ($id === null || !array_key_exists($id, EVENTS)) {
        $error = 'Невідомий захід.';
    } elseif ($action === 'add') {
        if (!in_array($id, $list, true)) {   // повторне додавання не створює дубліката
            $_SESSION['favorites'][] = $id;
        }
        setFlash('«' . EVENTS[$id] . '» додано до обраного.');
        redirect('favorites.php');
    } else {
        // Видалення відсутнього заходу не є помилкою.
        $_SESSION['favorites'] = array_values(array_filter($list, fn($item): bool => $item !== $id));
        setFlash('«' . EVENTS[$id] . '» прибрано з обраного.');
        redirect('favorites.php');
    }
    http_response_code(400);
} elseif (($_SERVER['REQUEST_METHOD'] ?? 'GET') !== 'GET') {
```

«Завершити сеанс» — окремий обробник. Він очищає `$_SESSION`, видаляє cookie `session_name()` з тими самими параметрами (`session_get_cookie_params()`) і викликає `session_destroy()`. Перенаправлення відбувається лише тоді, коли обидві операції успішні.

```
requireValidPost();

$_SESSION = [];
$params = session_get_cookie_params();
$cookieDeleted = setcookie(session_name(), '', [
    'expires' => time() - 3600,
    'path' => $params['path'],
    'domain' => $params['domain'],
    'secure' => $params['secure'],
    'httponly' => $params['httponly'],
    'samesite' => $params['samesite'],
]);
$destroyed = session_destroy();

if (!$cookieDeleted || !$destroyed) {
    http_response_code(500);
    exit('Не вдалося завершити сеанс.');
}
// Тема й історія відвідувань (постійні cookies) не змінюються.
header('Location: index.php?ended=1', true, 303);
exit;
```

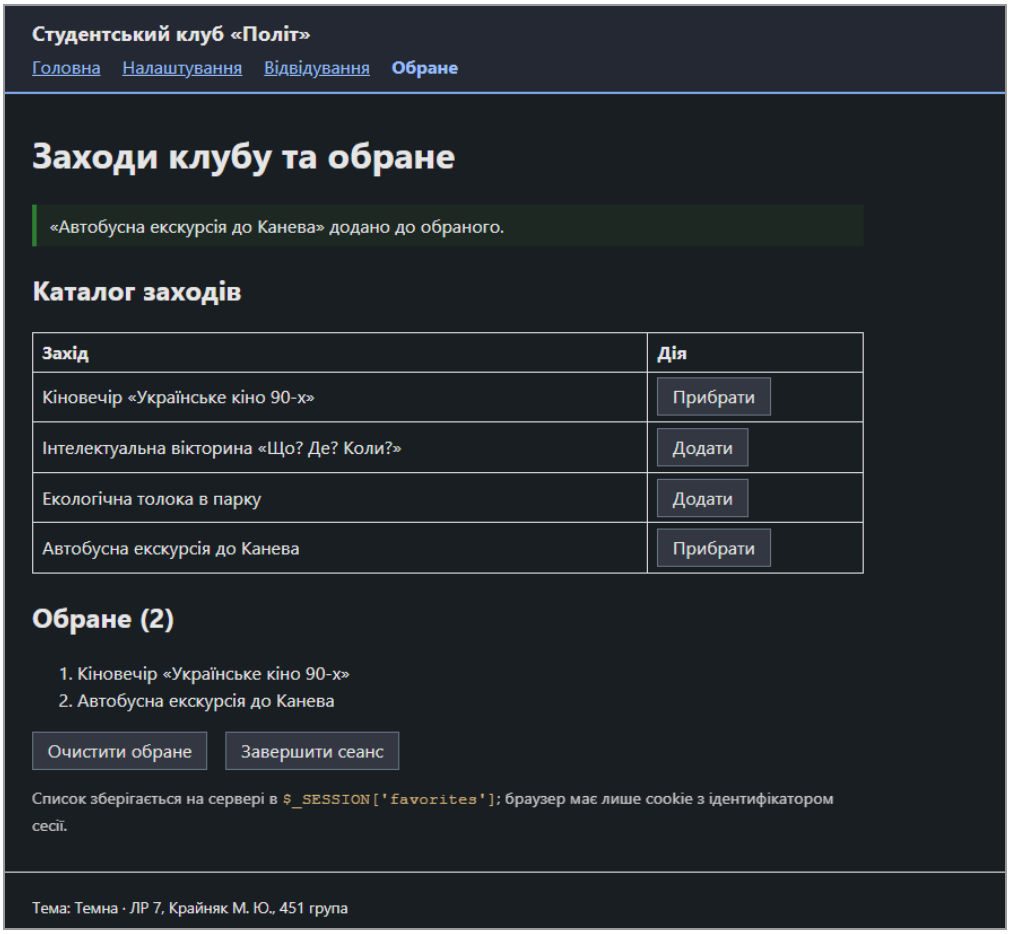


Рис. 9. `favorites.php` після додавання двох заходів. Кнопка змінюється з «Додати» на «Прибрати»; кнопки мають доступні назви з назвою заходу (`aria-label`).

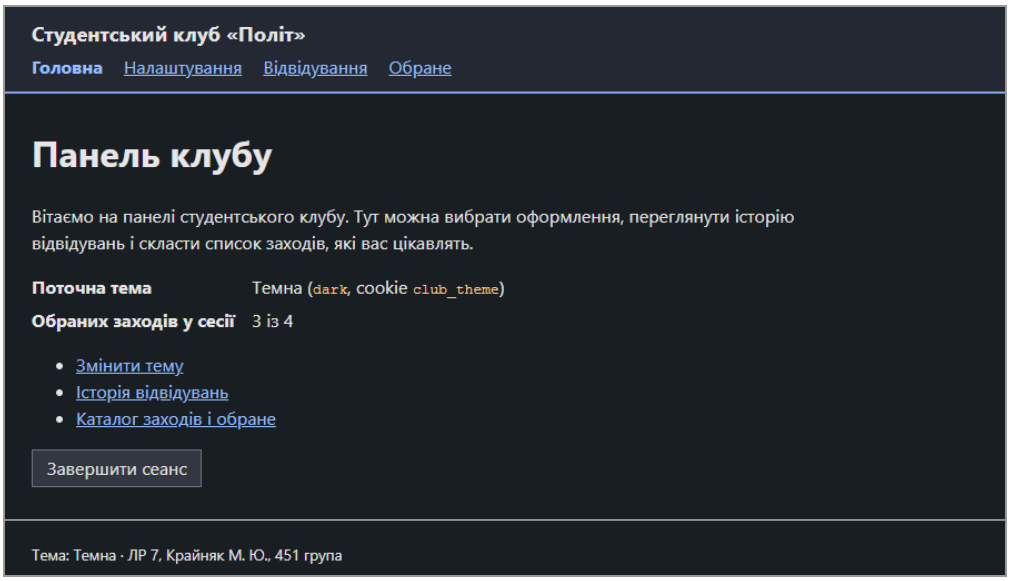


Рис. 10. Спільний стан різних сторінок і вкладок. У другій вкладці того самого браузера додано «Вікторину»; перша вкладка після оновлення показує на `index.php` «3 із 4».

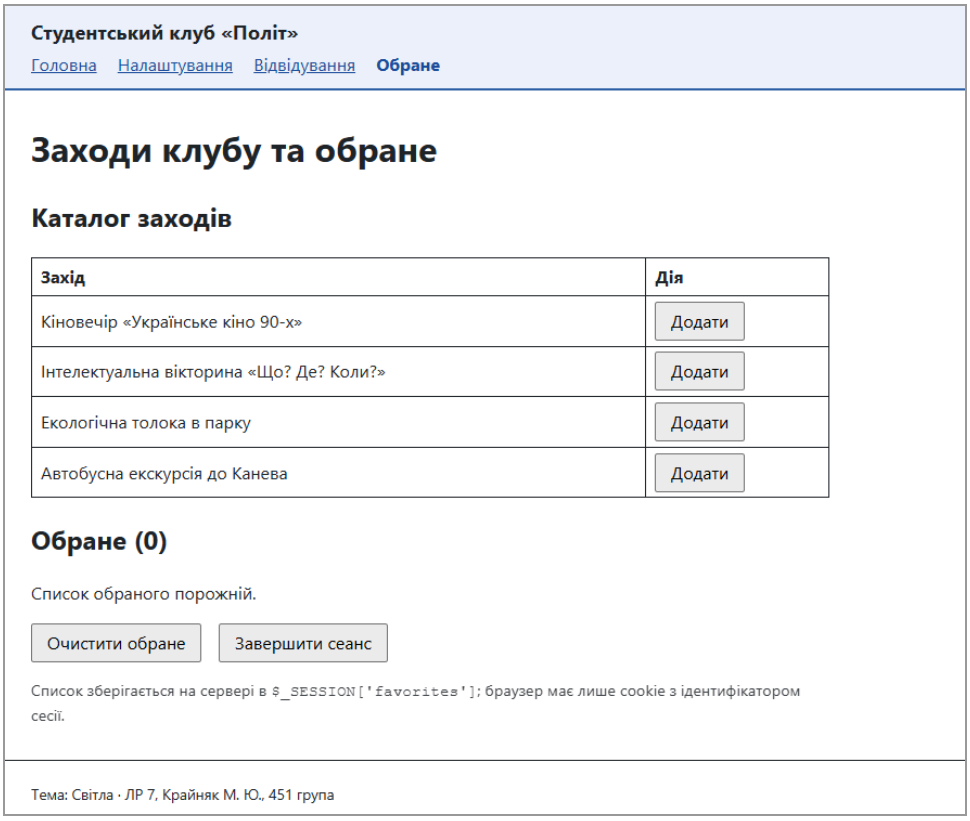


Рис. 11. Окремий приватний контекст браузера (аналог вікна InPrivate): світла тема, порожнє обране, інший ідентифікатор сесії.

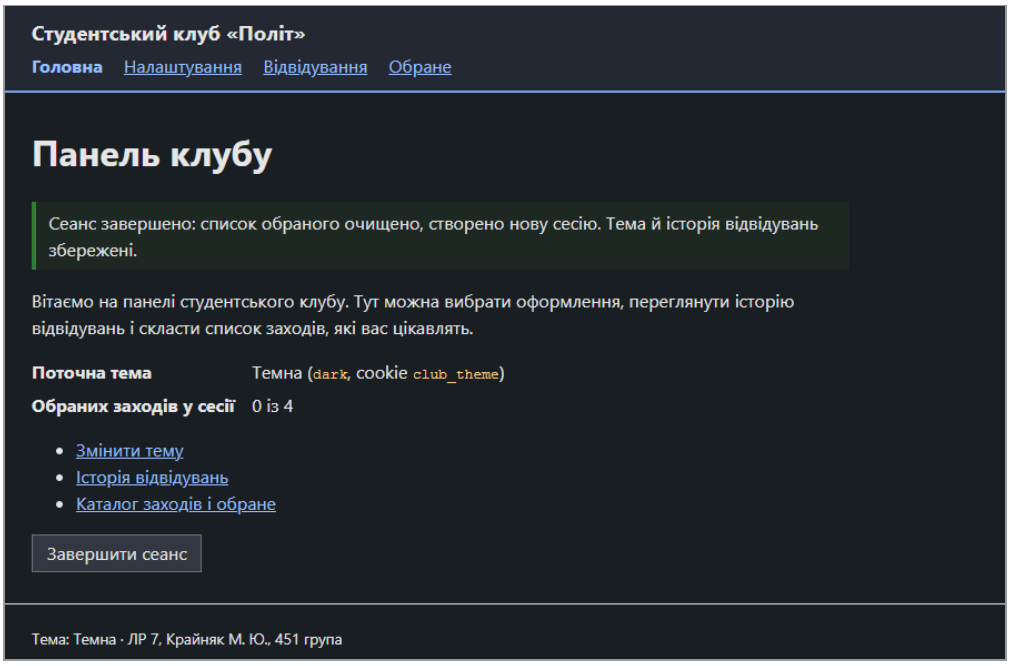


Рис. 12. Після «Завершити сеанс»: обране порожнє, а тема (темна) й історія відвідувань збережені.

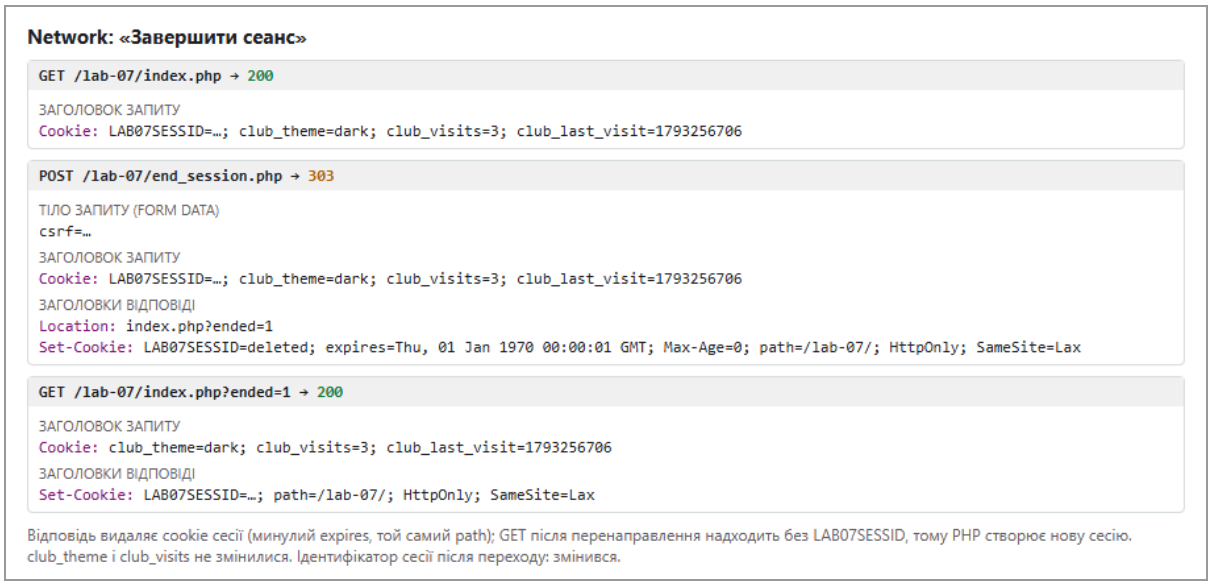


Рис. 13. Відповідь на POST `end_session.php` видаляє `LAB07SESSID` (дата в минулому, той самий path). Наступний GET іде без ідентифікатора, і PHP створює нову сесію з новим CSRF-токеном.

Крок 5. Розширення: одноразове повідомлення в сесії

Обрано третю ідею. Обробник записує текст у `$_SESSION['flash']` перед перенаправленням. Шаблон сторінки показує його один раз і видаляє (`takeFlash()`, рис. 3, 9). Після оновлення сторінки повідомлення немає. Текст екранується. Оскільки сесію після «Завершити сеанс» знищено, повідомлення про завершення передається параметром `?ended=1`; це лише ознака для показу тексту, стану вона не змінює.

```
/** Розширення (крок 5): одноразове повідомлення в сесії, показується після перенаправлення. */
function setFlash(string $message): void
{
    $_SESSION['flash'] = $message;
```

```
}

function takeFlash(): ?string
{
    $message = $_SESSION['flash'] ?? null;
    unset($_SESSION['flash']);
    return is_string($message) ? $message : null;
}
```

Помилки введення, захист і особливі стани

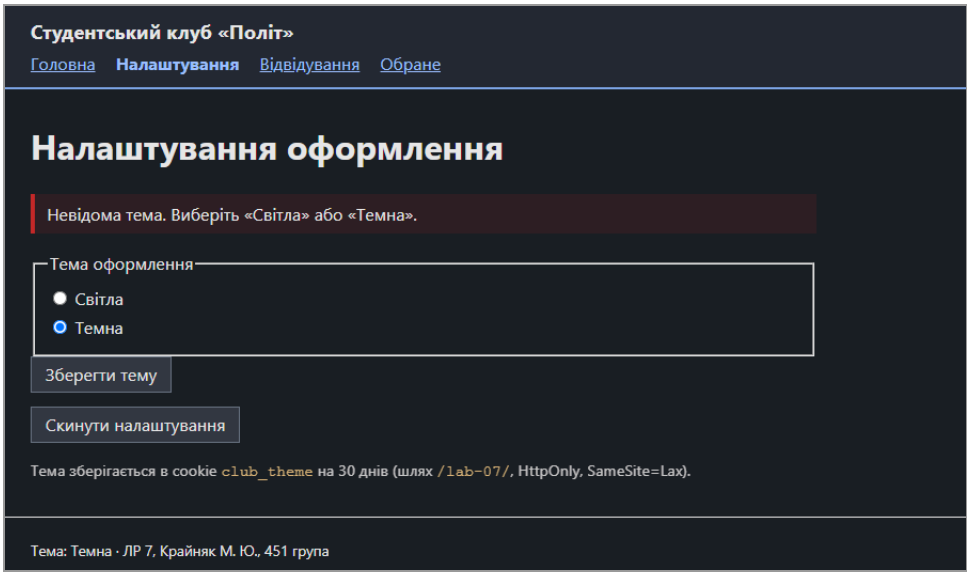


Рис. 14. У браузері значення радіокнопки змінено на `blue`. Відповідь 400 «Невідома тема», cookie `club_theme` лишилася `dark`.

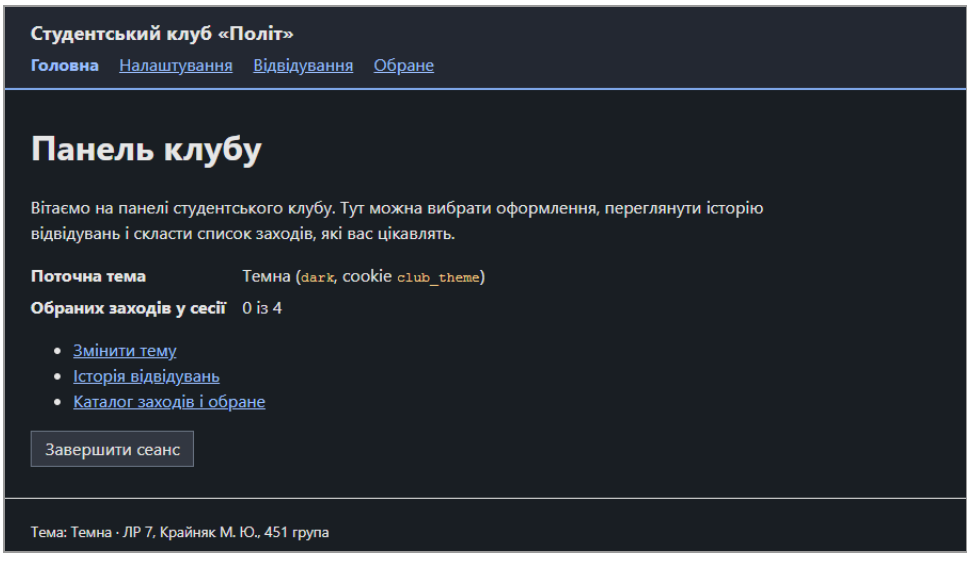


Рис. 15. Браузер закрито й відкрито знову з тим самим профілем: тема збережена, обране порожнє (сесійна cookie зникла).

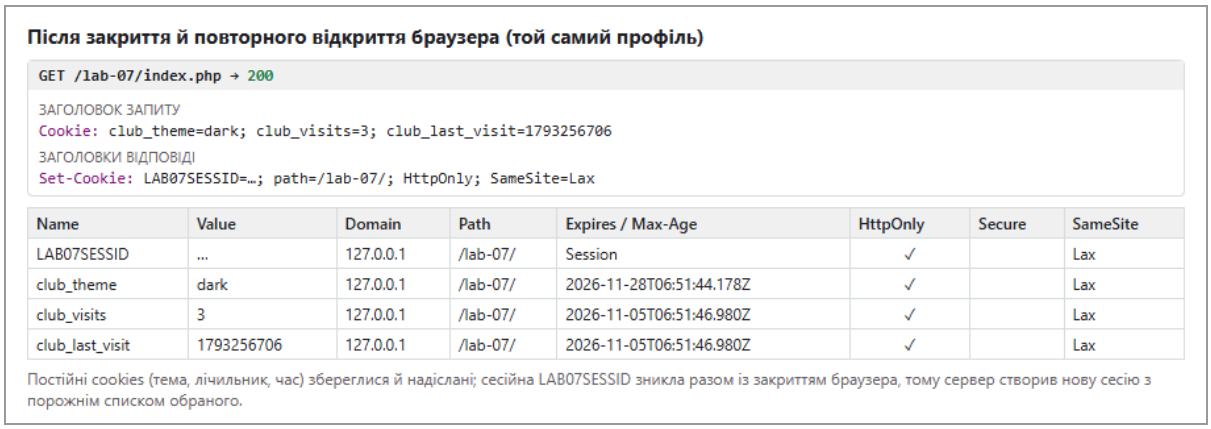


Рис. 16. Після перезапуску запит надсилає `club_theme`, `club_visits` і `club_last_visit`, але не `LAB07SESSID`. Сервер створює нову сесію. Наступний перегляд `visits.php` має номер 4.

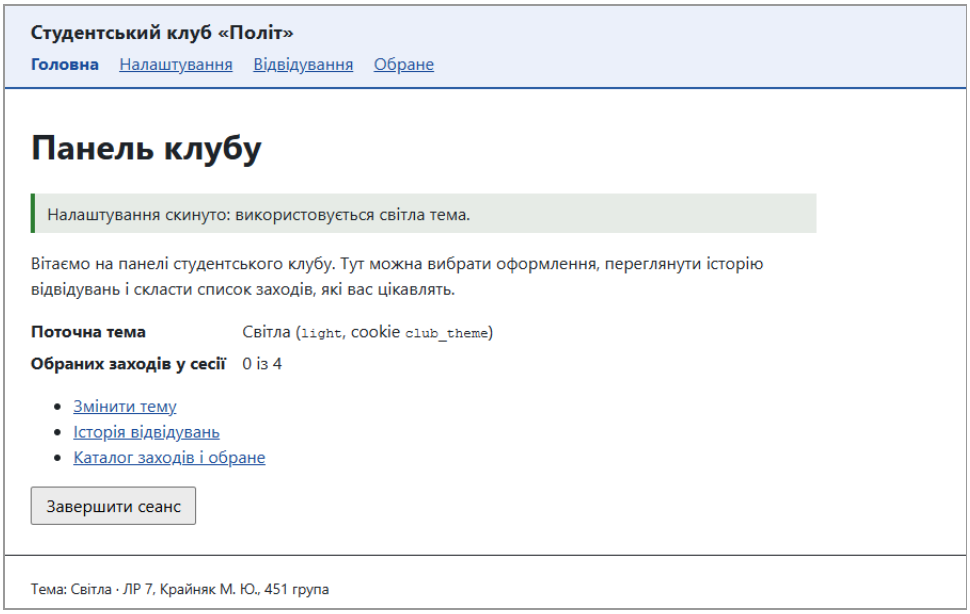


Рис. 17. «Скинути налаштування»: `Set-Cookie: club_theme=deleted; expires=Thu, 01 Jan 1970 …; Max-Age=0; path=/lab-07/`. Cookie зникла зі сховища, застосовано світлу тему.

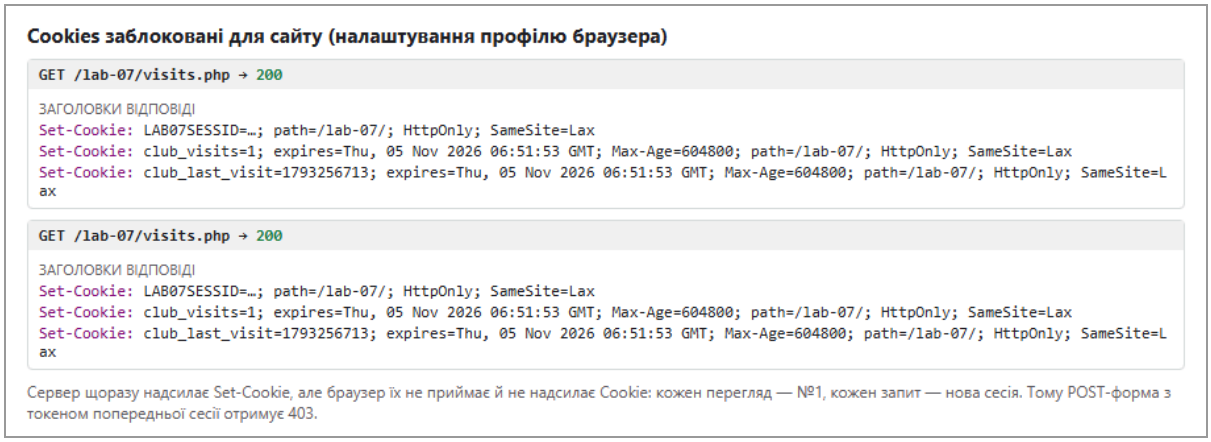


Рис. 18. У профілі браузера заблоковано cookies для сайтів. `visits.php` щоразу показує номер 1, кожен запит отримує нову сесію.



Рис. 19. З заблокованими cookies POST «Додати» отримує 403 «Недійсний токен форми.»: токен на сторінці належить сесії, яку браузер не зберіг. Таку саму відповідь отримує змінений токен у звичайному режимі (сценарій 11).

5. Перевірка: сценарії й результати

Джерела: `tools/checks-output.txt` (curl) і `results/browser-output.txt` (Edge). Некоректні cookies задавалися заголовком `Cookie` так само, як після редагування значень у сховищі браузера. Масивні cookies передавалися іменами `club_theme[test]` і `club_visits[x]`, масивні поля POST — іменами на кшталт `theme[]`. Перед кожним сценарієм використовувалося нове сховище cookies, тобто початковий стан.

№	Сценарій	Вхідні дані	Очікуваний результат	Фактичний результат	Висновок
1	Перший GET без cookies	Порожнє сховище; `index.php`, `visits.php`, `favorites.php`	Світла тема, порожнє обране; привітання й номер 1	200; `theme-light`, «0 із 4»; «Ласкаво просимо!», №1, «Попередній час недоступний»; «Список обраного порожній»	**Виконано**
2	Збереження темної теми	POST `action=save`, `theme=dark`, токен	POST → 303 → GET; тема на різних сторінках	303, `Location: index.php`, `Set-Cookie: club_theme=dark … Max-Age=2592000`; на `index`, `preferences`, `visits`, `favorites` — `theme-dark`	**Виконано**
3	Повторне відкриття браузера	Edge закрито й запущено з тим самим профілем; у curl — `-j` (відкидає сесійні cookies)	Тема й історія зберігаються	Тема темна; лічильник продовжився (№3 → №4); `LAB07SESSID` не відновлено, обране порожнє	**Виконано**
4	Скидання теми	POST `action=reset`	Cookie видалено для правильного шляху, light	`club_theme=deleted; expires=1970…; Max-Age=0; path=/lab-07/`; у сховищі cookie немає; `theme-light`	**Виконано**
5	Другий і третій GET `visits.php`	Три GET поспіль із паузою 1 с	Номери 2 і 3; час попереднього перегляду	№1 (привітання) → №2 з часом першого → №3 з часом другого перегляду	**Виконано**
6	Межові значення лічильника	`club_visits` = 0, 999998, 999999	1, 999999, 999999	Показано й записано 1, 999999, 999999	**Виконано**

№	Сценарій	Вхідні дані	Очікуваний результат	Фактичний результат	Висновок
7	Некоректний лічильник	-1, 1.5, 1000000, 007, abc, порожнє; масив `club_visits[x]=5`	Номер 1 без warning чи TypeError	Усі випадки: 200, «Ласкаво просимо!», №1; службових повідомлень PHP немає (сервер з `display_errors=1`)	**Виконано**
8	Відсутній, майбутній або некоректний час	`club_visits=5`; час відсутній, `time()+3600`, 0, abc, -5, 1.5, масив	«Час недоступний», лічильник працює	Усі випадки: «Попередній час недоступний», №6	**Виконано**
9	Некоректна тема в cookie	`unknown`, `<b>dark</b>` (також URL-кодовано), `DARK`, « dark», масив `club_theme[test]`	Світла тема, розмітка не виконується, помилок немає	Скрізь `theme-light`; тег `<b>` у відповідь не потрапляє; попереджень немає	**Виконано**
10	Невідома дія, тема чи захід; масив замість поля	`action=delete`, без `action`, `theme=blue`, `theme=<b>dark</b>`, `theme[]`, `action[]`, `id=party`, `id=<script>`, без `id`, `id[]`	Відмова без зміни стану	400 «Невідома дія / тема / захід»; `Set-Cookie club_theme` відсутній; тема й кількість обраних ті самі (рис. 14)	**Виконано**
11	CSRF-токен	Відсутній, змінений, `csrf[]` — для `preferences`, `favorites` (`add`, `clear`), `end_session`	HTTP 403 без зміни стану	12 із 12 запитів: 403 «Недійсний токен форми.»; тема, обране й ідентифікатор сесії не змінилися	**Виконано**
12	Двічі доданий захід	`add cinema` двічі	Один запис	Один запис; `remove eco`, якого не було, — 303 без помилки	**Виконано**
13	Оновлення після POST	Оновлення сторінки після 303 (curl і `Page.reload` у Edge)	Дія не повторюється	Оновлюється GET `favorites.php`; кількість не змінилася (2)	**Виконано**
14	Друга вкладка того самого браузера	Edge: додати «Вікторину» у другій вкладці	Спільний список після оновлення	Перша вкладка: «3 із 4» (рис. 10)	**Виконано**
15	Окремий приватний контекст	Edge: новий контекст браузера; curl: окреме сховище	Незалежні налаштування, історія й сесія	Світла тема, 0 обраних, №1 на `visits.php`, інший ідентифікатор сесії (рис. 11)	**Виконано**
16	Очищення обраного і завершення сеансу	POST `clear`; POST `end_session.php`	В обох випадках список порожній; лише завершення створює нову сесію	`clear`: 0 обраних, ідентифікатор сесії й токен не змінилися. Завершення: `LAB07SESSID=deleted`; після переходу ідентифікатор і токен змінилися, тема й історія збережені; старий токен → 403	**Виконано**

№	Сценарій	Вхідні дані	Очікуваний результат	Фактичний результат	Висновок
17	Cookies заблоковані для сайту	Edge: блокування cookies у профілі; curl без сховища	Тема й історія не зберігаються; POST може отримати 403	Щоразу №1, кожен запит — нова сесія; тема світла; POST «Додати» і «Зберегти тему» → 403 (рис. 18–19)	**Виконано**
18	Строк дії з коротким інтервалом	Час завершення `club_theme` у сховищі curl змінено на +2 с	Прострочена cookie не надсилається	Одразу — `theme-dark`, через 3 с — `theme-light`. Строки в заголовках: 2592000 с (30 днів) і 604800 с (7 днів). Код після перевірки не змінювався	**Виконано**
19	Інший хост	Тема dark на `127.0.0.1`, запит до `localhost:8070`	Cookies іншого хоста не надсилаються	`theme-light`	**Виконано**
20	Неправильний метод	GET `end_session.php`, POST `visits.php`, PUT `preferences.php`	Відмова без зміни стану	405 з `Allow: POST` / `Allow: GET` / `Allow: GET, POST`	**Виконано**
21	HttpOnly	`document.cookie` у браузері	JavaScript не бачить cookies	`""`, хоча у сховищі 4 cookies (рис. 5)	**Виконано**
22	Валідація HTML	Згенерований HTML 10 станів сторінок (обидві теми, повідомлення, 400-відповіді)	Без помилок	W3C Nu HTML Checker: 0 повідомлень для кожної сторінки	**Виконано**

Невиконаних перевірок немає. Один сценарій виконано не дослівно: «приватне вікно» в Edge без вікна відтворено окремим контекстом браузера (`Target.createBrowserContext`). Саме так браузер ізолює вікно InPrivate: окреме сховище cookies.

6. Вивід автоматичних перевірок (curl)

```
Адреса: http://127.0.0.1:8070/lab-07
PHP вебсервера: PHP/8.2.12

== 1. Перший GET без cookies
index.php: 200 / тема theme-light, обраних 0
      Set-Cookie: LAB07SESSID=…; path=/lab-07/; HttpOnly; SameSite=Lax
visits.php: 200 / №1, попередній: Попередній час недоступний, «Ласкаво просимо!»
      Set-Cookie: club_visits=1; expires=Thu, 05 Nov 2026 06:46:06 GMT; Max-Age=604800; path=/lab-07/;
HttpOnly; SameSite=Lax
      Set-Cookie: club_last_visit=1793256366; expires=Thu, 05 Nov 2026 06:46:06 GMT; Max-Age=604800;
path=/lab-07/; HttpOnly; SameSite=Lax
favorites.php: 200 / обраних 0: Список обраного порожній

== 2. Збереження темної теми (POST → 303 → GET)
POST save dark: 303 → index.php
      Set-Cookie: club_theme=dark; expires=Sat, 28 Nov 2026 06:46:07 GMT; Max-Age=2592000; path=/lab-07/;
HttpOnly; SameSite=Lax
   GET index.php: 200 / тема theme-dark | Тему «Темна» збережено на 30 днів.
   preferences.php: тема theme-dark
   visits.php: тема theme-dark
```

```
   favorites.php: тема theme-dark
   оновлення index.php: тема theme-dark, повідомлення: (одноразове — вже немає)
   в cookie-сховищі: club_theme=dark, прапорець HttpOnly: 1

== 3. Інший хост: localhost замість 127.0.0.1
http://localhost:8070/lab-07/index.php: 200 / тема theme-light — cookies 127.0.0.1 не надіслано

== 4. Повторне відкриття браузера (curl -j відкидає сесійні cookies, як закритий браузер)
visits.php до закриття: №3, попередній: 29.10.2026 08:46:08
favorites додано quiz перед закриттям: 1 обраних
після «перезапуску»: index 200 / тема theme-dark, обраних 0
   visits.php: №4, попередній: 29.10.2026 08:46:10
   ідентифікатор сесії: змінився (сесійна cookie LAB07SESSID не зберігається після закриття)

== 5. Скидання теми
POST reset: 303 → index.php
      Set-Cookie: club_theme=deleted; expires=Thu, 01 Jan 1970 00:00:01 GMT; Max-Age=0; path=/lab-07/;
HttpOnly; SameSite=Lax
   GET index.php: тема theme-light | Налаштування скинуто: використовується світла тема.; club_theme у
сховищі: 0

== 6. Другий і третій GET visits.php (нове сховище)
GET 1: 200 / №1, попередній: Попередній час недоступний, «Ласкаво просимо!»
GET 2: 200 / №2, попередній: 29.10.2026 08:46:13
GET 3: 200 / №3, попередній: 29.10.2026 08:46:14
      Set-Cookie: club_visits=3; expires=Thu, 05 Nov 2026 06:46:16 GMT; Max-Age=604800; path=/lab-07/;
HttpOnly; SameSite=Lax
      Set-Cookie: club_last_visit=1793256376; expires=Thu, 05 Nov 2026 06:46:16 GMT; Max-Age=604800;
path=/lab-07/; HttpOnly; SameSite=Lax

== 7. Межові значення лічильника (cookie задано вручну)
club_visits=0 → №1, попередній: 29.10.2026 08:45:16 | записано: club_visits=1
club_visits=999998 → №999999, попередній: 29.10.2026 08:45:17 | записано: club_visits=999999
club_visits=999999 → №999999, попередній: 29.10.2026 08:45:18 | записано: club_visits=999999

== 8. Некоректний лічильник
club_visits='-1' → 200 / №1, попередній: Попередній час недоступний, «Ласкаво просимо!»
club_visits='1.5' → 200 / №1, попередній: Попередній час недоступний, «Ласкаво просимо!»
club_visits='1000000' → 200 / №1, попередній: Попередній час недоступний, «Ласкаво просимо!»
club_visits='007' → 200 / №1, попередній: Попередній час недоступний, «Ласкаво просимо!»
club_visits='abc' → 200 / №1, попередній: Попередній час недоступний, «Ласкаво просимо!»
club_visits='' → 200 / №1, попередній: Попередній час недоступний, «Ласкаво просимо!»
club_visits[x]=5 (масив) → 200 / №1, попередній: Попередній час недоступний, «Ласкаво просимо!»

== 9. Відсутній, майбутній або некоректний попередній час (лічильник 5)
club_last_visit='' → №6, попередній: Попередній час недоступний
club_last_visit='1793259982' → №6, попередній: Попередній час недоступний
club_last_visit='0' → №6, попередній: Попередній час недоступний
club_last_visit='abc' → №6, попередній: Попередній час недоступний
club_last_visit='-5' → №6, попередній: Попередній час недоступний
club_last_visit='1.5' → №6, попередній: Попередній час недоступний
club_last_visit[x]=1 (масив) → №6, попередній: Попередній час недоступний

== 10. Некоректна тема в cookie
club_theme='unknown' → 200 / тема theme-light, сирий тег <b> у відповіді: 0
club_theme='<b>dark</b>' → 200 / тема theme-light, сирий тег <b> у відповіді: 0
club_theme='%3Cb%3Edark%3C%2Fb%3E' → 200 / тема theme-light, сирий тег <b> у відповіді: 0
club_theme='DARK' → 200 / тема theme-light, сирий тег <b> у відповіді: 0
club_theme=' dark' → 200 / тема theme-light, сирий тег <b> у відповіді: 0
club_theme[test]=dark (масив) → 200 / тема theme-light

== 11. Невідома дія, тема чи захід; масив замість поля POST (стан не змінюється)
початковий стан: тема theme-dark, обраних 1
preferences action=delete: 400 Невідома дія.; Set-Cookie club_theme: 0
preferences без action: 400 Невідома дія.; Set-Cookie club_theme: 0
preferences theme=blue: 400 Невідома тема. Виберіть «Світла» або «Темна».; Set-Cookie club_theme: 0
preferences theme=<b>dark</b>: 400 Невідома тема. Виберіть «Світла» або «Темна».; Set-Cookie club_theme:
0
```

```
preferences theme[]=light: 400 Невідома тема. Виберіть «Світла» або «Темна».; Set-Cookie club_theme: 0
preferences action[]=reset: 400 Невідома дія.; Set-Cookie club_theme: 0
favorites action=delete: 400 Невідома дія.
favorites id=party: 400 Невідомий захід.
favorites id=<script>: 400 Невідомий захід.
favorites без id: 400 Невідомий захід.
favorites id[]=quiz: 400 Невідомий захід.
favorites action[]=clear: 400 Невідома дія.
стан після відмов: тема theme-dark, обраних 1
GET end_session.php: 405 Потрібен POST-запит., Allow: POST
POST visits.php: 405 Сторінка відвідувань приймає лише GET., Allow: GET
PUT preferences.php: 405 Метод не підтримується.

== 12. CSRF-токен: відсутній, змінений, масивом (HTTP 403, стан не змінюється)
preferences.php [action=save&theme=light]: без токена 403; змінений 403; масив 403 Недійсний токен форми.
favorites.php [action=add&id=quiz]: без токена 403; змінений 403; масив 403 Недійсний токен форми.
favorites.php [action=clear]: без токена 403; змінений 403; масив 403 Недійсний токен форми.
end_session.php [x=1]: без токена 403; змінений 403; масив 403 Недійсний токен форми.
стан: тема theme-dark, обраних 1, ідентифікатор сесії не змінився

== 13. Обране: двічі доданий захід, видалення відсутнього, оновлення після POST
add cinema: 303 → favorites.php
add cinema ще раз: 303 → favorites.php
add trip: 303 → favorites.php
GET favorites.php: обраних 2: Кіновечір «Українське кіно 90-х»;Автобусна екскурсія до Канева | «Автобусна
екскурсія до Канева» додано до обраного.
оновлення (повторний GET після 303): обраних 2 — POST не повторено
remove eco (не було в списку): 303 → favorites.php; обраних 2
remove cinema: 303 → favorites.php; обраних 1: Автобусна екскурсія до Канева
кількість на index.php: 1

== 14. Друга вкладка (той самий cookie-файл) і приватний контекст (окремий)
add quiz у першій вкладці: 303
друга вкладка, GET favorites.php: обраних 2: Автобусна екскурсія до Канева;Інтелектуальна вікторина «Що?
Де? Коли?»
приватний контекст: index 200 / тема theme-light, обраних 0; visits: №1, попередній: Попередній час
недоступний, «Ласкаво просимо!»
сесії різні: так

== 15. Очищення обраного і завершення сеансу
clear: 303 → favorites.php; обраних 0; ідентифікатор сесії не змінився; токен не змінився
знову додано eco: обраних 1
POST end_session.php: 303 → index.php?ended=1
      Set-Cookie: LAB07SESSID=deleted; expires=Thu, 01 Jan 1970 00:00:01 GMT; Max-Age=0; path=/lab-07/;
HttpOnly; SameSite=Lax
   LAB07SESSID у сховищі після відповіді: 0
   GET index.php?ended=1: 200 | Сеанс завершено: список обраного очищено, створено нову сесію. Тема й
історія відвідувань збережені.; тема theme-dark, обраних 0
      Set-Cookie: LAB07SESSID=…; path=/lab-07/; HttpOnly; SameSite=Lax
   ідентифікатор сесії після переходу: змінився; CSRF-токен: змінився
   історія збережена: club_visits=1 → visits.php №2, попередній: 29.10.2026 08:46:45
   старий токен після завершення: 403 Недійсний токен форми.

== 16. Cookies заблоковані (кожен запит без cookies)
visits.php запит 1: 200 / №1, попередній: Попередній час недоступний, «Ласкаво просимо!»
visits.php запит 2: 200 / №1, попередній: Попередній час недоступний, «Ласкаво просимо!»
POST save dark з токеном зі сторінки: 403 Недійсний токен форми. — сесію втрачено
index.php: тема theme-light

== 17. Строк дії: тимчасово короткий інтервал (час завершення club_theme у сховищі змінено на +2 с)
Max-Age теми: Max-Age=2592000 (30 днів = 2592000); visits: Max-Age=604800 (7 днів = 604800)
одразу: тема theme-dark
через 3 с: тема theme-light — прострочену cookie не надіслано
```

7. Порівняння з початковими демонстраціями

Файли з `given/src` запущено без змін (`results/given-demos.txt`):

```
== GET cookie_set.php
HTTP/1.1 200 OK
Set-Cookie: username=Student; expires=Thu, 29 Oct 2026 07:45:54 GMT; Max-Age=3600; path=/
Set-Cookie: age=20; expires=Thu, 29 Oct 2026 07:45:54 GMT; Max-Age=3600; path=/
    <p>Cookie встановлені!</p>
== GET cookie_get.php
HTTP/1.1 200 OK
    <p>Ім'я: Student</p>
    <p>Вік: 20</p>
== GET cookie_delete.php
HTTP/1.1 200 OK
Set-Cookie: username=deleted; expires=Thu, 01 Jan 1970 00:00:01 GMT; Max-Age=0; path=/
Set-Cookie: age=deleted; expires=Thu, 01 Jan 1970 00:00:01 GMT; Max-Age=0; path=/
    <p>Cookie видалені!</p>
== GET session_simple.php
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=…; path=/
    <p>Сесія відкрита. Ім'я користувача: Student</p>
== GET session_counter.php
HTTP/1.1 200 OK
    <p>Ви відвідали цю сторінку 1 раз(ів).</p>
== GET session_counter.php
HTTP/1.1 200 OK
    <p>Ви відвідали цю сторінку 2 раз(ів).</p>
== GET cookie_get.php з Cookie: username[x]=1 (масив)
TypeError: htmlspecialchars(): Argument #1 ($string) must be of type string, array given in
given/src/cookie_get.php:7
```

Недоліки демонстрацій і те, як їх виправлено в роботі:

- `path=/` — cookie надсилається всім застосункам хоста. У роботі шлях `/lab-07/`.
- Немає атрибутів HttpOnly і SameSite. У роботі вони є.
- Стан змінюється через GET без токена: будь-яке посилання встановлює чи видаляє cookies. У роботі зміни йдуть через POST із CSRF-токеном і 303.
- Сесія використовує стандартне ім’я `PHPSESSID` зі шляхом `/` і без HttpOnly. У роботі — `LAB07SESSID`, `use_strict_mode` і `use_only_cookies`.
- `session_simple.php` виводить значення сесії без `htmlspecialchars()`. У роботі всі тексти виводяться через `e()`.
- `cookie_get.php` не перевіряє тип: масив `username[]` викликає TypeError у `htmlspecialchars()`. У роботі кожне значення перевіряється на рядковий тип і допустимий перелік або діапазон.

8. Відповіді на контрольні питання

1. **Set-Cookie і Cookie.** `Set-Cookie` — заголовок *відповіді* сервера. Він пропонує браузеру зберегти одну cookie з атрибутами (`expires`/`Max-Age`, `path`, `domain`, `Secure`, `HttpOnly`, `SameSite`); на кожну cookie — окремий заголовок. `Cookie` — заголовок *запиту* браузера.

Він містить лише пари «ім'я=значення» всіх відповідних cookies, без атрибутів (рис. 4).

2. **Чому до виведення.** `setcookie()`, `session_start()` (надсилає cookie сесії) і `header()` формують HTTP-заголовки. Заголовки надсилаються перед тілом відповіді. Після першого байта виведення (HTML, пробіл, BOM) їх уже надіслано, тож PHP видає «headers already sent», і функція не діє.
3. **Чому `$_COOKIE` не містить нового значення.** `$_COOKIE` заповнюється один раз із заголовка `Cookie` поточного запиту. `setcookie()` лише додає `Set-Cookie` до відповіді. Браузер збереже значення після отримання відповіді й надішле його в наступному запиті. Тому після збереження теми виконується перенаправлення.
4. **expires, path, domain.** `expires` визначає, доки браузер зберігає cookie; 0 або відсутність означає сесійну cookie до закриття браузера. `path` — для яких шляхів її надсилати (`/lab-07/` — лише для цього застосунку). `domain` — для якого хоста; без нього лише для поточного. Щоб видалити cookie, треба надіслати її з минулим `expires` і *тими самими* `path` та `domain`. Інакше браузер вважатиме це іншою cookie, і стара лишиться.
5. **Secure, HttpOnly, SameSite.**
   - `Secure` — надсилати лише через HTTPS. Значення cookie він не шифрує.
   - `HttpOnly` — cookie недоступна JavaScript через `document.cookie`, що зменшує шкоду від XSS. «Лише HTTP без шифрування» він не означає.
   - `SameSite=Lax` — не надсилати cookie в більшості міжсайтових запитів, наприклад у POST з чужого сайту. Це доповнює захист від CSRF, але токен не замінює.
6. **Перевірка значень, паролі.** Cookie зберігається у клієнта, і користувач може змінити її, видалити або надіслати масив чи розмітку. Тому значення перевіряються за типом і переліком або діапазоном, як у `currentTheme()` і `cookieInt()`. Паролі й хеші в cookies не зберігають: їх видно у сховищі й мережі, вони потрапляють у кожен запит, їх можна викрасти. Права доступу визначаються лише на сервері.
7. **Де дані сесії.** На сервері: типово у файлах `sess_<id>` каталогу `session.save_path`, можливі й інші обробники (БД, Redis). Браузер зберігає лише ідентифікатор у cookie `LAB07SESSID` і надсилає його з кожним запитом. За ним `session_start()` завантажує `$_SESSION`.
8. **unset(), очищення `$_SESSION`, session_destroy().**
   - `unset($_SESSION['favorites'])` видаляє один запис, сесія лишається.
   - `$_SESSION = []` очищає всі дані поточного запиту, і порожній масив буде збережено.
   - `session_destroy()` видаляє серверні дані сесії. Масив `$_SESSION` у поточному виконанні вона не очищає, а cookie з ідентифікатором не видаляє — тому в `end_session.php` виконуються всі три дії.

9. **Закриття браузера.** Сервер не дізнається про закриття браузера. Серверні дані живуть до `session_destroy()` або до очищення за `session.gc_maxlifetime`. Браузер може відновити сесійні cookies разом із вкладками. Тому вихід має бути явною дією.
10. **CSRF-токен, екранування, перенаправлення.** Токен підтверджує, що POST надіслано з форми нашого сайту, а не з чужої сторінки, яка використала cookies користувача. Екранування `htmlspecialchars()` не дає даним стати HTML або JavaScript (XSS). Перенаправлення 303 після POST замінює POST в історії на GET, тож оновлення сторінки не повторює дію.
11. **Вкладки й приватний контекст.** Вкладки одного профілю браузера мають спільне сховище cookies. Тому вони надсилають той самий ідентифікатор сесії й бачать спільний `$_SESSION` (рис. 10). Приватне вікно має окреме тимчасове сховище: свої cookies, свою сесію, інші налаштування (рис. 11).
12. **Лічильник у cookie.** Він рахує перегляди одного браузера, а не людей. Одна людина з кількома браузерами чи пристроями дасть кілька лічильників. Видалення cookies, приватний режим або блокування скидають лічильник. Користувач може записати будь-яке значення. Боти й клієнти без cookies щоразу дають №1. Достовірна статистика ведеться на сервері.

9. Висновок

Створено «Панель студентського клубу» на чистому PHP.

- Тема й історія відвідувань — це постійні несекретні cookies з атрибутами `path=/lab-07/`, HttpOnly і SameSite=Lax.
- Список обраного зберігається на сервері в сесії, браузер має лише її ідентифікатор.
- Усі зміни стану — POST із CSRF-токеном і перенаправленням 303.
- Значення `$_COOKIE` і `$_POST` перевіряються за типом і допустимими значеннями, виведення екранується.

Усі 22 сценарії виконано у curl і в браузері Edge. Попереджень PHP немає навіть із `display_errors=1`, HTML валідний.

Виправлені помилки. Порівняно з початковими демонстраціями виправлено:

- широкий `path=/`;
- відсутність HttpOnly і SameSite;
- зміну стану через GET без токена;
- виведення без екранування;
- відсутність перевірки типу (масив у cookie спричиняв TypeError).

Під час перевірок у браузері з’ясувалося таке. Нова тема в поточному запиті ще не діє, тому зміни показуються лише після перенаправлення. Сеанс у `end_session.php` треба завершувати трьома діями: очищення масиву, видалення cookie, знищення серверних даних. Одна `session_destroy()` лишає cookie і масив.

Обмеження cookies.

- Малий розмір і кількість.
- Значення повністю під контролем клієнта і можуть бути змінені, видалені або заблоковані.
- Cookies прив’язані до хоста й шляху (`localhost` і `127.0.0.1` — різні сховища).
- Новий стан видно лише в наступному запиті.
- Без HTTPS атрибут Secure неможливий, і значення передаються відкрито.

Тому cookies придатні лише для несекретних налаштувань, а права доступу, ціни, статистика й секрети мають зберігатися на сервері.